Functional Working MVP (~0.42 ms Inspection Latency)

BASTION WAF

High-Performance Inline Web Application Firewall for Local Digital Systems

RS

Robel Shitahun

3rd Year Cybersecurity Student, Faculty of Computing

Bahir Dar Institute of Technology (BiT), Bahir Dar University • Target Center: BiTec

The Problem: Web Defense in Ethiopia

Local web platforms operate with zero baseline perimeter protection due to three structural barriers.

1

The Foreign Currency Barrier

Commercial cloud firewalls (Cloudflare, AWS WAF) demand recurring subscriptions billed strictly in US Dollars via international credit cards. Severe domestic forex restrictions legally cut off local developers, startups, and academic platforms.

2

The Operational Complexity Deficit

Open-source alternatives like raw ModSecurity lack an intuitive graphical UI, requiring continuous manual terminal configuration and complex regex tuning. Small teams and regional developers routinely misconfigure or abandon them.

3

The Institutional Defense Divide

While federal agencies have specialized enterprise solutions, ordinary university portals, student platforms, and growing regional enterprises are left completely unshielded against automated botnets and vulnerability fuzzers.

The Target Market: The "Missing Middle"

Bastion protects the critical tier of institutions that handle real user data locally but cannot access foreign firewalls.

SECTOR 01

Campus Networks & Departmental Services

BiT student portals, grading platforms, and faculty research tools facing 24/7 automated network scanning without dedicated security staff or enterprise security operations centers.

SECTOR 02

Regional SMEs & Software Houses

Local tech startups, e-commerce shops, and private clinics processing customer transactions entirely in Ethiopian Birr (ETB) and needing a turnkey, zero-headache perimeter firewall.

SECTOR 03

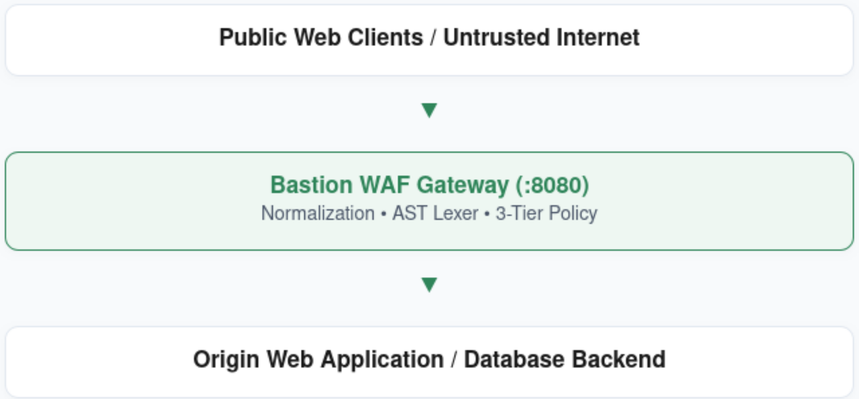
Public Regional Platforms

Municipal and educational bureaus legally or policy-bound to keep all traffic data, inspection telemetry, and audit logs strictly on physical, on-premises local servers within national borders.

The Solution: Bastion WAF Overview

A high-throughput, self-hosted inline reverse proxy providing sub-millisecond perimeter protection.

- **Inline Reverse-Proxy Gateway**
  Intercepts incoming HTTP/HTTPS traffic at the network edge before it can touch backend databases or application logic.
- **Runs on Standard Commodity Hardware**
  Engineered for high throughput on standard quad-core desktop PCs without demanding expensive specialized hardware.
- **Autonomous Protection Suite**
  28 active defense rules protecting across OWASP Top 10, API Security, and Automated Bot Scanners.
- **100% Domestic Billing**
  Fully commercialized in Ethiopian Birr (ETB) with native Telebirr and CBE Birr payment integrations.



Core Defense Pipeline (How It Works)

A multi-stage inspection flow engineered for deep payload de-obfuscation and sub-millisecond execution.

STEP 1

Multi-Pass Normalization Layer

Recursively resolves multi-stage URL encoding, HTML entities, Unicode NFKC homoglyphs, and comment injection techniques (e.g. `UNI/**/ON`) before any rule evaluation.

STEP 2

Hybrid Inspection Suite

Dual raw and canonical payload representations evaluated concurrently against 28 Core Rule Set (CRS) signatures across OWASP Top 10, API, and Bot threats.

STEP 3

Context-Aware Semantic AST Lexer

Parses structural grammar tokens to evaluate true execution intent and boolean tautologies, rather than relying on flawed blind keyword matching.

STEP 4

Fail-Safe Operation Engine

Configurable Passive Monitor (Bypass) Mode for safe staging, alongside a Fail-Open safety switch to guarantee continuous application availability.

Key Innovation: Semantic AST vs. Legacy RegEx

How Bastion eliminates false positives on normal human text while stopping evasive zero-day attacks.

The Failure of RegEx Firewalls

Static keyword filters trigger false alarms on normal human language, breaking legitimate application features when words match attack patterns.

```
Blocks: "select goods from shop"
Blocks: "1 < 2 in math class"
Bypassed by: "UN/**/ION SELECT"
```

Bastion's AST Lexical Tokenizer

Parses code syntax into Abstract Syntax Trees, evaluating boolean tautologies (`'1'='1'`) and genuine command execution chains (`|`, `&&`, `;`).

```
Allows: "select goods from shop"
Allows: "1 < 2 in math class"
Blocks: "' OR '1'='1 --" (True Tautology)
```

- **Zero False Positives on Conversational Queries**
- **Ultra-Low Overhead: Sub-Millisecond Deterministic Parsing**
- **Explainable Token Scores Without Heavy Machine Models**

3-Tier Adaptive Bot & Threat Mitigation

Replacing blunt "block-or-allow" walls with human-centric adaptive verification.

TIER 1 • HIGH RISK

High-Confidence Exploits (Score ≥ 70)

Confirmed attacks (SQLi, RCE, Webshells) are dropped instantly at the gateway boundary. No backend application execution occurs, saving origin server compute.

Action: Immediate HTTP 403 Forbidden Drop

TIER 2 • SUSPICIOUS

Suspicious Anomalies (Score 40–69)

Suspicious traffic and automated bot scrapers are served an in-house interactive Slider CAPTCHA, verifying human mouse trajectory smoothness and velocity without third-party cloud APIs.

Action: Interactive Slider CAPTCHA Challenge

TIER 3 • VERIFIED CLEAN

Clean / Human Traffic (Score < 40)

Legitimate users and CAPTCHA-cleared clients receive a cryptographically signed HMAC token (15-min TTL) and are forwarded seamlessly to upstream application servers.

Action: HTTP 200 Forward Upstream

Current MVP Status & Benchmark Results

Empirical performance metrics measured on standard commodity desktop hardware.

~0.42 ms

Average Inspection Latency

Verified locally across 10,000+ concurrent mixed HTTP requests (clean traffic, nested SQLi, encoded XSS, path traversal).

< 140 MB

RAM Footprint

Highly optimized async engine running on standard Linux x86_64 commodity hardware alongside the telemetry server.

103 / 103

Passing Automated Tests

Full test suite verifying zero false negatives across all 28 active OWASP, API, and bot detection rules.

1,000 RPS

Incubation Target Metric

Scaling to sustain 1,000 Requests Per Second with a 99th-percentile latency under 1.5 ms on a standalone commodity desktop PC.

Operational Telemetry & Management Dashboard

A self-contained web console replacing terminal configuration with intuitive real-time visibility.





- **Real-Time SOC Telemetry**
  Visualizes live traffic throughput, mitigation percentages, challenge distributions, and host system health vitals (CPU/RAM/Uptime).

- **Authentic Threat Analytics**
  Tracks real database-persisted attack vectors (targeted URL endpoints, triggered rule IDs, source IP frequencies) without fake external cloud lookups.

- **One-Click Rule Management**
  Toggle any of the 28 security rules on/off dynamically in memory via the browser with zero server restarts required.

- **Interactive Threat Sandbox**
  Test custom request payloads and inspect AST scores before deploying rules into live production traffic.

Competitive Advantage

Comparing Bastion against international cloud providers and legacy open-source tools.

Evaluation Feature	Cloudflare / AWS WAF	ModSecurity / Coraza	Bastion WAF (Proposed)
Billing & Currency	Monthly USD (Credit Card)	Free (High Labor Cost)	**100% Ethiopian Birr (Telebirr / CBE)**
Data Residency	Overseas Cloud Servers	Local / Self-Hosted	**Strictly On-Premises Sovereignty**
Management Interface	Cloud Console	Command-Line Files (.conf)	**Interactive Real-Time Web UI**
Detection Engine	Proprietary Heuristics	Static Regex Matching	**Semantic AST Lexer + CRS Rules**
Bot Challenge	Cloudflare Turnstile	Basic Rate Limits	**Self-Hosted Adaptive Slider CAPTCHA**
Hardware Overhead	Cloud Infrastructure	Moderate / High CPU Spikes	**Sub-millisecond on Commodity PCs**

Business Model & Revenue Strategy

Sustainable domestic monetization billed via local mobile money (Telebirr, CBE Birr).

CHANNEL 01

Tiered Subscriptions (SaaS)

- **Academic Tier (0 ETB / Free):** Free for student projects & campus research labs.
- **Commercial SME Tier (1,500 – 2,500 ETB / mo):** Automated rule updates, managed proxy routing, and direct alerts.
- **Agency Multi-Domain Tier (4,000 – 6,000 ETB / mo):** Up to 10 client domains managed in a unified console.

CHANNEL 02

On-Premise Enterprise

- **Self-Hosted Enterprise License (20,000 – 35,000 ETB / yr):** For regional banks and public municipal offices requiring air-gapped data residency.
- **Turnkey Appliance Delivery (30,000 – 50,000 ETB one-time):** Pre-hardened mini-PC appliance delivered for direct server-room deployment.

CHANNEL 03

Domestic Partnerships

- **Hosting Provider Add-on (300 – 500 ETB / domain / mo):** Wholesale integration with domestic hosting providers during checkout.
- **Software Agency Bundling:** Regional software houses pre-installing Bastion as the baseline security layer on custom client portals.

Phased Development Roadmap

Clear engineering milestones to advance from a working prototype to an enterprise appliance.

STAGE 1

Current Working Prototype (Completed)

Fast reverse proxy, sub-millisecond AST parser, 28-rule CRS suite, Slider CAPTCHA, and centralized dashboard.

STAGE 2

Months 1–3 @ BiTec: Traffic Baselining & Rate Limiting

Implementing sliding-window rate limiting, client connection frequency tracking, and behavioral scanning baselining.

STAGE 3

Months 4–6 @ BiTec: Zero-Day Anomaly Detection

Adding lightweight local classification models to recognize polymorphic injection mutations and automated parameter fuzzing.

STAGE 4

Months 7–9 @ BiTec: Plain-Language AI Summaries

Automated incident reporting that converts raw request dumps and regex logs into plain-language incident explanations and patch advice.

Incubation Ask: Why BiTec?

Four essential incubator resources requested to transition Bastion into production.

1

Workstation & Continuous Electrical Power

Dedicated workstation access with dependable electrical power and network connectivity to conduct sustained 48-hour traffic stress tests, fuzzing pipelines, and proxy benchmarking.

2

Isolated Security Testing Subnet

A closed virtual lab environment to safely execute attack tools (SQLMap, Nuclei) against test targets through Bastion without risking campus network stability.

3

Faculty Technical Mentorship

Advisory guidance from BiT computing professors on socket pooling, high-throughput concurrency, and statistical anomaly modeling.

4

Campus Staging Pilot Authorization

Permission to test Bastion in Passive Monitor (Bypass) Mode in front of an internal departmental test service to validate real-world reliability with zero downtime risk.